

Shadow IT Asset Discovery response

Shadow IT · **High** severity · SOC IR Playbook

Incident type	Asset Management / Policy Violation
Severity	High
Priority	High if linked to sensitive systems or users
Detection sources	CASB, EDR, SIEM, Asset Discovery Tools, Proxy Logs, DNS Logs, Employee Tip-Offs

Scenario

A previously unknown or unauthorised IT asset (e.g., cloud service, SaaS application, personal laptop, rogue Wi-Fi access point or unapproved web app) is discovered operating within or connected to the corporate environment, potentially bypassing security controls and increasing risk exposure.

MITRE ATT&CK

T1078, T1087.001, T1584

Preparation

Maintain up-to-date asset inventory Use CMDB or automated asset discovery tools Deploy CASB and endpoint telemetry Detect unapproved SaaS use or external connections Define acceptable use and app policies Include clear guidance on what users are allowed to use Monitor outbound DNS and proxy logs Identify unusual domains or services in use Educate staff on Shadow IT risks Regular training and acceptable use policy (AUP) awareness

Detection & Analysis

Alert from CASB or network logs Unapproved application or cloud service usage Discover rogue device or access point From network scans, NAC alerts or EDR telemetry Correlate with user or department Identify user or business unit responsible for use Assess risk and scope What data was accessed, where it's stored and who used it

Containment

Block unauthorised service or domain Via firewall, DNS or proxy controls Disable rogue asset network access Using NAC, switchport disablement or Wi-Fi controls Revoke user access To unauthorised apps or tools discovered in use Notify responsible teams Work with the team or user who introduced the asset to understand business intent

Eradication

Remove unapproved software From endpoints, servers or internal systems Decommission rogue infrastructure Shutdown VMs, containers, cloud services or local hosts not in inventory Clean credentials If passwords or tokens were shared with unauthorised systems Update asset discovery signatures Add new detection rules for similar tools or configurations in future scans

Recovery

Onboard approved replacements Help users move to authorised tools or services Restore normal access Only after all affected systems are validated and secured Update asset inventory Include newly discovered legitimate systems under official tracking Revalidate user roles Ensure no privilege creep or policy bypass remains active

Lessons Learned & Reporting

Document incident timeline What was found, how, when and by whom Improve user workflows Provide secure and supported alternatives to Shadow IT solutions Revise acceptable use policy Clarify rules and include escalation for exceptions Share incident report With IT, security governance and department leads Conduct follow-up audits To verify similar assets or services are not in use elsewhere

Tools typically involved

CASB (e.g., Netskope, Microsoft Defender for Cloud Apps, McAfee MVISION); SIEM (e.g., Splunk, Sentinel, QRadar); Endpoint tools (e.g., CrowdStrike, Cortex XDR); Network scanners (e.g., Nmap, Qualys, Nessus, Fing); DNS/Proxy logs and analytics (e.g., Cisco Umbrella, Squid, Zscaler); CMDB / IT asset management (e.g., ServiceNow, Lansweeper)

Success metrics (SLA targets)

Detection Time <1 day from introduction of asset Containment Time <4 hours from confirmation Asset Inventory Update Time Within 24 hours post-incident User Re-education Completion 100% of involved users retrained within 7 days Policy Compliance Enforcement Confirmed for similar cases during next audit cycle